Project - Security Requirements

Aleksander Kłap

08.06.2026

1 Security Requirements

SR-01	**Network Segmentation**
SR-01.1	The network shall be divided into the following security zones: - OT Field Zone (PLCs, HMIs) - OT Cell Zone (MQTT Device, Cobot / ML vision PC, Engineering Workstation) - Industrial DMZ (OPC UA Proxy, MQTT Broker, Backup Server, Historian) - IT Zone (MES Server, COBOL Vision System)
SR-01.2	Each zone shall be implemented as a separate subnet/VLAN. Communication between zones shall only be permitted through firewall-controlled conduits.
SR-01.3	Direct communication from the IT Zone to the OT Field Zone shall be prohibited.
Standards Reference	- IEC 62443-3-3 SR 5.1 – Restricted Data Flow - IEC 62443-1-1 – Zone and Conduit Model - NIS2 Article 21(2)(d)

SR-02	**Firewall with protocol inspection**
SR-02.1	The OT zones and IT zone shall be separated with the industrial firewall(s).
SR-02.2	Firewall rules shall enforce default-denay policy on all inter-zone traffic, with only explicitly whitelisted flows permitted: - OPC UA (TCP port 4840) from IMDZ OPC UA proxy to PLC's and Festo Controllers - MQTT (TCP port 8883 TLC) from MQTT device to MQTT broker in IDMZ
Standards Reference	- IEC 62443-3-3 SR 5.2 - IEC 62443-2-1 security management

SR-03	**OPC UA Hardening**
SR-03.1	All OPC UA servers shall operate in Security Mode: Sign&Encrypt with SecurityPolicy:Basic256Sha256.
SR-03.2	Each client (MES, COBOL) must authenticate with an application certificate. Annonymous and username/password authentication sessions shall be disabled.
SR-03.3	OPC/UA servers shall not be reachable from the nodes inside IT zone directly, all access routes shall be set through a dedicated OPC UA proxy in IDMZ
Standards Reference	- IEC 62443-3-3 SR 1.1, SR 1.3, SR 3.1; OPC UA Part 2 (Security Model)

SR-04	**MQTT Hardening**
SR-04.1	The MQTT broker shall be hosted on a dedicated server inside IDMZ. All MQTT connections shall use TLS 1.2 or higher.
SR-04.2	Each MQTT publusher (MQTT CXV device) shall authenticate with a client certificate.
SR-04.3	Topic level ACLs must restrict publishers only to its own publish topics.
SR-04.4	Nodes in IT zone shall only subscribe (not publush) to the OT topics.
Standards Reference	- IEC 62443-3-3 SR 1.1, SR 3.1; MQTT v5 specification; NIS2 Article 21(2)(h)

SR-05	**HTTP/Web Service Hardening**
SR-04.1	All HTTP services on PLC's HMI's, Festo Controllers, and cameras shall be disabled unless strictly required for an operational functionality.
SR-04.2	If the Web Interface is required, it must be migrated to HTTPS (TLS 1.2+) with a device certificate, and access restricted by firewall to only sepcific source IP's of pooling systems.
SR-04.3	Topic level ACLs must restrict publishers only to its own publish topics.
SR-04.4	Nodes in IT zone shall only subscribe (not publush) to the OT topics.
Standards Reference	- IEC 62443-3-3 SR 1.1, SR 3.1; MQTT v5 specification; NIS2 Article 21(2)(h)

SR-06	**Authentication and Least Privilage**
SR-06.1	All interactive access (PLC programming, HMI configuration, robot controller configuration) to the OT devices shall require individual user authentication.
SR-06.2	Role separation shall be enforced: - Operator (monitor only) - Engineer (upload programs, change parameters) - Administrator (device configuration, user management)
SR-06.3	PLC Programming access (TIA Portal) shall be only possible from designated Engineering Workstation.
Standards Reference	- IEC 62443-3-3 SR 1.1–1.3; - IEC 62443-2-1 §4.3.3; - ISO/IEC 27001 A.9

SR-07	**Secure Engineering Access**
SR-07.1	A dedicated Engineering Workstation shall be physically or logically isolated from the IT Zone.
SR-07.2	The Engineering Workstation shall connect to PLC's only through industrial firewall via controlled conduit, with firewall rules permitting only TIA Portal protocols to the PLC's IP's.

SR-08	**Logging and Monitoring**
SR-08.1	All network devices (managed switches, routers, industrial firewalls, PLC's with switch modules) shall send logs to a centralized Syslog collector.
SR-08.2	The industrial firewalls shall log all denied traffic.
SR-08.3	OPC UA server shall log all sessions establishment and authentication failiures.
SR-08.4	The MQTT brocker shall log all connect/disconnect events and authentication failiures.
Standards Reference	- IEC 62443-3-3 SR 6.1, SR 6.2; - NIS2 Article 21(2)(f); - ISO/IEC 27001 A.12.4

SR-09	**NTP/Time synchronization**
SR-09.1	A single NTP server must be designated. All OT devices shall synchronize using this server.
Standards Reference	- IEC 62443-2-1 §4.3.4; ISO/IEC 27001 A.12.3; NIS2 Article 21(2)(c)

SR-10	**NTP/Time synchronization**
SR-10.1	All PLC programs, HMI and Controllers configurations must be backed up after every change to and dedicated backup storage.
SR-10.2	Backup must be stored offline.
SR-10.3	Recovery procedure shall be documented and tested at least once per half a year.
SR-10.4	MES database shall be backed up once a day.
Standards Reference	- IEC 62443-2-1 §4.3.4; - ISO/IEC 27001 A.12.3; - NIS2 Article 21(2)(c)